



Л Е К Ц И Я 0 3

Постановка задач машинного обучения в сценариях информационной безопасности

НИУ ВШЭ – МИЭМ · ОП «Информационная безопасность и технологии искусственного интеллекта»

Курс «Машинное обучение и безопасность систем» · 1 курс магистратуры

Автор: Силаев Ю. В. · Время самостоятельного изучения: ~ 60 минут · 47 слайдов



О чём эта лекция за одну минуту

2 / 47

Часть 1 · Введение

Ключевой тезис, на который будем опираться дальше

Машинное обучение в задачах информационной безопасности – это не выбор алгоритма, а инженерная работа по построению проверяемого решения. Качество ML-решения начинается не с модели, а с постановки задачи: что именно мы анализируем, что предсказываем, как используется результат, и какой ценой обходятся ошибки.

В большинстве реальных провалов ML-проектов в SOC, антифрод-системах и фильтрах фишинга причина не в том, что выбран «слабый» алгоритм. Причина в том, что задача была поставлена так, что её решение не нужно пользователю системы: метрика модели не отражает цель системы, объект анализа выбран неудачно, разметка не соответствует сценарию использования, а baseline вообще никто не сравнивал.

КЛЮЧЕВОЙ ТЕЗИС ЛЕКЦИИ

Модель машинного обучения в задачах информационной безопасности нельзя оценивать отдельно от сценария применения, источников данных, цены ошибок и способа использования результата.



Пять учебных результатов

После самостоятельного изучения этой лекции вы сможете осознанно ставить ML-задачу в сценарии ИБ, а не «обучать модель» по инерции. Ниже – пять конкретных умений.

- 1 Различать пять базовых типов ML-задач – классификацию, регрессию, ранжирование, кластеризацию и обнаружение аномалий – и видеть, какой тип уместен в конкретном ИБ-сценарии.
- 2 Формулировать ML-задачу через четыре элемента: объект анализа, признаки, целевая переменная, доступные данные – а не как «обучить модель».
- 3 Объяснять специфику ИБ-данных: редкость атак, шум и задержку разметки, изменчивость поведения, асимметрию цены ошибок.
- 4 Определять, где в системе безопасности возникает ML-компонент, какое решение он поддерживает и в каком режиме используется его результат.
- 5 Отделять эксплуатационную цель системы (например, разгрузить SOC) от технической метрики модели (например, F1 на тестовом срезе).



Что нужно знать до начала

Предварительные требования и опора на предыдущие лекции курса

Лекция концептуальная: формул и алгоритмов здесь не будет. Но чтобы материал лёг осмысленно, нужно опираться на несколько вещей – частично из общей подготовки, частично из предыдущей лекции курса.

из общей подготовки

- теория вероятностей и матстатистика: распределения, оценки, гипотезы;
- линейная алгебра: векторы, матрицы, скалярное произведение;
- матанализ: производные, градиенты, цепное правило;
- Python, numpy и pandas – на уровне работы с табличными данными;
- общие понятия ИБ: типы атак, активы, концептуальная модель угроз.

из лекции L02 «данные и ЕДА»

- что такое объект, признак и целевая переменная в табличных данных;
- как смотреть на датасет: распределения, пропуски, выбросы;
- понимание того, что данные имеют структуру и историю происхождения, а не приходят «из ниоткуда»;
- базовое представление, что в ИБ-данных бывают зависимости по времени и источнику.

Метрики, валидацию, leakage и конкретные модели обсуждать пока не нужно – это темы L04-L08. Здесь работаем на уровне постановки задачи.



План лекции

5 / 47

Часть 1 · Введение

Семь частей, 47 слайдов, около 60 минут самостоятельного изучения

часть лекции	слайды	время
1 Введение в лекцию	1 - 5	6 мин
2 Мотивация: зачем правильная постановка задачи	6 - 9	5 мин
3 Основное содержание – четыре смысловых блока	10 - 37	34 мин
4 Связки с практикой ИБ	38 - 41	5 мин
5 Итоги лекции	42 - 44	4 мин
6 Источники для углубления	45 - 46	2 мин
7 Глоссарий	47	1 мин
ИТОГО	47 слайдов	≈ 60 мин



Почему ML-проекты в ИБ часто не доходят до продакшна

Постановочный тезис части: причина не в алгоритме, а в постановке задачи

В академических и индустриальных обзорах ML в ИБ устойчиво воспроизводится наблюдение: значительная часть проектов либо не выходит из стадии прототипа, либо разворачивается, но через несколько месяцев перестаёт использоваться SOC или владельцем системы. При этом сами модели обычно работают: точность, ROC-AUC и F1 на тестовой выборке – приемлемые.

Где сидит реальная причина?

ЧТО ОБЫЧНО ВИНЯТ

- слабый алгоритм – «нужна нейросеть посовременнее»;
- мало данных – «нужен датасет побольше»;
- плохая инфраструктура – «не хватает GPU/MLOps»;
- недостаточно тюнинга гиперпараметров.

ЧТО ОБЫЧНО ОКАЗЫВАЕТСЯ ПРИЧИНОЙ

- объект анализа выбран не тот, что нужен пользователю;
- метрика модели не отражает цель системы;
- разметка не соответствует сценарию использования;
- режим использования (автомат / триаж / помощник) не определён.



Кейс: SOC, утопающий в алертах

7 / 47

Часть 2 · Мотивация

Реальный сценарий, где «хорошая модель» оказалась бесполезной

ИБ - КЕЙС

Команда из 4 ML-инженеров обучила классификатор сетевых соединений «нормальное / подозрительное». На тесте получили $F1 = 0.92$, $\text{precision} = 0.89$, $\text{recall} = 0.95$. Модель развернули в SOC крупной телеком-компании.

Что произошло после развёртывания

~ 4 800

алертов в сутки от модели

12

аналитиков в смене SOC

~ 3 мес

и модель отключили

Почему «хорошая» модель оказалась бесполезной

Аналитики SOC физически не успевали разбирать 4 800 алертов в сутки – задача была не «обнаружить подозрительные соединения», а **приоритизировать те, что нужно проверить в первую очередь**. Это другая постановка – *ранжирование, а не классификация*. Метрика $F1$ не отражала эту цель: даже $\text{precision} = 0.89$ при потоке 4 800 алертов даёт ~500 ложных срабатываний в день – больше, чем команда успевает обработать.



Чем платит инженер за плохую постановку задачи

Три типовые цены, которые видны не на тестовой выборке, а в эксплуатации

Кейс с SOC – не единичный случай. Когда задача поставлена так, что её решение не совпадает с целью системы, инженер платит за это тремя типовыми способами. Все три цены неочевидны на этапе обучения модели – они проявляются позже, в эксплуатации.

1

Пропущенный инцидент

Модель не реагирует на то, что для системы – главный риск. Атака проходит, потому что задача формулировалась без учёта, какие именно события важно ловить. Метрика «recall на тестовом срезе» этого не показывает: на новых атаках recall другой.

2

Перегрузка аналитиков

Модель выдаёт больше алертов, чем команда может обработать. Аналитики либо игнорируют поток целиком, либо разбирают первые попавшиеся – то есть фактически работают без модели. Полезный сигнал тонет в шуме.

3

Потерянное доверие

После нескольких ложных срабатываний или громких пропусков владелец системы перестаёт верить ML-компоненту в принципе. Даже хорошая следующая модель команды будет встречена скептически – кредит доверия исчерпан.



Что мы будем делать дальше

Мост к четырём смысловым блокам основного содержания

Мы научимся ставить ML-задачу так, чтобы расхождение между метрикой модели и целью системы не возникало в принципе. Для этого пройдем четыре смысловых блока. Каждый блок – отдельный инструмент.



**Модель как компонент
системы**

слайды 10 - 15



**Объект анализа и целевая
переменная**

слайды 16 - 22



**Типология ML-постановок в
ИБ**

слайды 23 - 31



**Данные, цена ошибок,
baseline**

слайды 32 - 37

К концу лекции · у вас будет рабочий чек-лист, чтобы формулировать ML-задачу в ИБ так, что её решение действительно нужно пользователю системы.



Б Л О К А



Модель как компонент системы

Главная идея этой лекции: ML-модель – это часть системы, не самостоятельный «умный блок». От этой рамки зависит, как мы дальше будем выбирать метрики, режим использования и порог.

слайды 10 - 15 · 6 слайдов



Четыре уровня: модель, эксперимент, система, сценарий

Опорные понятия лекции

МОДЕЛЬ

Функция, которая по объекту даёт предсказание. Имеет архитектуру, параметры, версию. Сама по себе – математический объект.

ЭКСПЕРИМЕНТ

Процедура обучения и проверки модели: данные, разбиение, гиперпараметры, метрики, журнал результатов. Воспроизводимая единица работы инженера.

СИСТЕМА

Программный комплекс, в который встроена модель: источники данных, предобработка, инференс, постобработка, интерфейс с человеком или другой системой.

СЦЕНАРИЙ ПРИМЕНЕНИЯ

Конкретная задача, ради которой система используется: кто и как принимает решение по её выходу, какой цели это служит, чем платит за ошибку.

Эти четыре понятия – единый язык курса. Дальше мы будем явно различать, на каком из уровней находимся: спрашиваем о модели, об эксперименте, о системе или о сценарии.



Куда встраивается ML-компонент

12 / 47

Часть 3 · Блок А

ML – один из шагов конвейера системы, а не вся система

В реальной системе ИБ ML-модель – это один блок в цепочке. До неё данные нужно собрать и подготовить. После неё результат должен быть превращён в решение и доведён до получателя – аналитика SOC, блокирующего шлюза или другой системы. Если выпадает любой из этих шагов, модель не работает.



ML-модель – третий шаг из пяти. Один шаг из пяти.

Качество системы – это произведение качества всех пяти шагов, а не только третьего. Если плохо собраны данные, плохо настроен порог или решение не доходит до пользователя – модель с любой метрикой бесполезна.



Три режима использования модели

13 / 47

Часть 3 · Блок А

Автомат, триаж, помощник – где в системе появляется человек

Один и тот же скор модели можно использовать тремя способами. От выбора режима зависит почти всё: какая метрика важна, какой порог выбирать, какова допустимая ошибка. Это часть постановки задачи, а не деталь реализации.

РЕЖИМ 1

Автомат

Решение исполняет система

Пример. Спам-фильтр блокирует письмо в карантин без участия человека.

Что важно. Цена FP высокая – пользователь теряет реальное письмо. Нужна высокая precision.

РЕЖИМ 2

Триаж

Модель ранжирует, человек разбирает сверху

Пример. SOC получает список из 100 алертов, отсортированных по риску, и разбирает первые 20.

Что важно. Важна не классификация «атака/нет», а порядок. Метрика – recall на top-k.

РЕЖИМ 3

Помощник

Решение всегда принимает человек

Пример. Антивирус показывает аналитику подсказку: «вероятно, упакованный malware», но решение – за ним.

Что важно. Допустимо больше ошибок: они не превращаются в действие. Важна интерпретируемость.

Как именно выбирать порог под выбранный режим – подробно разберём в L07 «Калибровка и выбор порога».



Частая ошибка: «обучу модель, потом подумаем, что с ней делать»

Самая распространённая ошибка постановки задачи в учебных и пилотных проектах

ЧАСТАЯ ОШИБКА

«Возьмём публичный датасет, обучим модель с хорошим F1, а потом подумаем, как её применить». Так формулирует задачу почти каждый студент и значительная часть инженеров, у которых нет опыта работы с ML в продакшне.

ПОЧЕМУ ЭТО НЕВЕРНО

Без сценария применения нельзя выбрать метрику. F1 = 0.95 на тесте ничего не говорит о пригодности модели: для «автомата» важен precision, для «триажа» – порядок и recall@k, для «помощника» – интерпретируемость.

Метрика выбирается под цель системы, а не наоборот. Если оптимизировали F1, а нужно было recall@100, лучшая по F1 модель почти никогда не лучшая по recall@100. Оптимизировали не то.

Чужая разметка может не соответствовать вашему сценарию. Метка «attack» в публичном датасете собиралась по правилам, которые могут не совпадать с тем, что вы ловите в эксплуатации. Модель учится чужому понятию атаки.



Что мы только что разобрали и понесём дальше

Установили рамку «модель как компонент системы» – на эту рамку дальше опирается вся лекция и значительная часть курса. Четыре главных тейкэвея блока:



Модель $\neq$ система

ML-компонент – один шаг из пяти в цепочке: данные $\rightarrow$ подготовка $\rightarrow$ модель $\rightarrow$ постобработка $\rightarrow$ решение. Качество системы – произведение качества всех пяти.



Четыре уровня – единый язык

Модель, эксперимент, система, сценарий применения. Обсуждая ML-задачу, всегда указывайте, на каком уровне вы находитесь.



Режим использования – часть постановки

Автомат, триаж или помощник – это решается до выбора метрики и алгоритма. Один и тот же скор по-разному используется в каждом режиме.



Метрика – следствие сценария

F1, precision, recall, recall@k, ROC-AUC – выбираются под цель системы, а не как «начальная настройка эксперимента».



Б Л О К Б



Объект анализа и целевая переменная

От того, что мы выбираем как единицу анализа и что мы метим как целевую переменную, зависит, какую задачу мы фактически решаем. Здесь же – проблема разметки в ИБ.

слайды 16 - 22 · 7 слайдов



Что такое объект анализа

Ключевой термин лекции

ОПРЕДЕЛЕНИЕ

Объект анализа — это единица данных, относительно которой модель делает одно предсказание. У задачи может быть один и тот же источник, но разные возможные объекты анализа — и выбор объекта определяет, какую задачу вы фактически решаете.

Типовые объекты анализа в ИБ-задачах

Файл

PE / ELF / документ

Сетевой пакет / flow

запись из NetFlow

Сессия пользователя

цепочка действий за окно

Лог-событие

строка в SIEM

Сообщение / текст

письмо, чат, URL

Алерт SOC

карточка инцидента



Объект анализа ≠ источник данных

18 / 47

Часть 3 · Блок Б

Из одного источника можно построить разные объекты – и это разные задачи

Источник данных и объект анализа – разные вещи. Источник – это «откуда у нас данные» (логи прокси, рсар-дампы, журналы антивируса). Объект анализа – это «что именно мы классифицируем». Из одного и того же источника можно построить несколько разных объектов, и каждый – это другая ML-задача с другими признаками, другой разметкой и другой метрикой.

Пример. Один источник: логи веб-прокси. Четыре возможных объекта анализа:

URL	HTTP-запрос	Сессия	Юзер · день
Классифицировать каждый отдельный URL: фишинг / нет.	Помечать подозрительные запросы: SQLi, XSS, обращение к C2.	Классифицировать пользовательскую сессию целиком.	Помечать аномальное поведение пользователя за сутки.
<i>Объектов: миллионы в сутки. Зависимости между URL – слабые.</i>	<i>Объектов: десятки миллионов. Признаки – заголовки, тело, метод.</i>	<i>Объектов: тысячи в сутки. Признаки – агрегаты по сессии.</i>	<i>Объектов: тысячи. Признаки – поведенческие агрегаты.</i>

Это не «варианты решения одной задачи» – это четыре разные ML-задачи с разными датасетами, разной разметкой и разными метриками. Выбор объекта – первый и часто самый недооцененный шаг постановки.



Что это и какой здесь объект анализа

ИБ-КЕЙС · СКВОЗНОЙ ДАТАСЕТ КУРСА

CIC-IDS-2018

~ 16 млн

flow-записей за 10 дней

80

признаков на запись

14 + 1

типов атак + Benign

Публичный датасет Canadian Institute for Cybersecurity. Захват реального сетевого трафика, имитирующего работу 470 машин в течение 10 рабочих дней. Признаки – статистики каждого flow (длительность, число пакетов, размеры, флаги TCP). Объект анализа – отдельный flow.

Что мы будем делать с этим датасетом дальше. В этой лекции – иллюстрация выбора объекта анализа. Полноценные расчёты: EDA в L02, метрики в L04, валидация в L05, линейные модели в L07, бустинг в L08, интерпретация в L09, обработка временной структуры в L12, robustness и drift в L17, evasion-атаки в L18.



Четыре типа целевой переменной на прикладных ИБ-примерах

Целевая переменная y – это то, что модель должна научиться предсказывать по объекту анализа. Её тип определяет тип задачи: бинарная классификация, многоклассовая, регрессия или ранжирование. Один и тот же объект (например, сетевой flow) может иметь четыре разные целевые переменные.

ТИП y	ЧТО ПРЕДСКАЗЫВАЕМ	ПРИМЕР В ИБ
Бинарная	$y \in \{0, 1\}$ – атака или нет.	Flow – атака / Benign на CIC-IDS-2018.
Многоклассовая	y из K классов – тип атаки.	Brute Force / DoS / Infiltration / Bot / Benign – 14 + 1 классов в CIC-IDS-2018.
Регрессия	$y \in \mathbb{R}$ – числовой риск или объём.	Прогноз ожидаемого ущерба от инцидента в денежных единицах.
Порядок / ранг	y задаёт относительный порядок объектов.	Ранжирование алертов SOC по приоритету разбора (триаж).

Тип y выбирается под сценарий применения, а не как «удобно». Если SOC может разобрать только верхушку списка – нужна задача ранжирования, а не классификации, даже если в данных лежит метка «attack / benign».



Откуда берётся целевая переменная и почему ей нельзя верить безоговорочно

В академическом ML разметка обычно дана и считается «истиной». В ИБ это не так. Метка у приходит от конкретного процесса разметки – и качество, полнота и своевременность этой разметки сами становятся частью постановки задачи.

ОТКУДА ПРИХОДИТ МЕТКА

- Решение аналитика SOC по итогам разбора инцидента.
- Вердикт антивируса или sandbox-системы.
- Сигнатурные правила IDS, фильтры почты.
- Жалоба пользователя или клиента.
- Внешние источники: threat intelligence, VirusTotal.
- Синтетическая разметка для публичных датасетов.

ЧТО С НЕЙ МОЖЕТ БЫТЬ НЕ ТАК

- Шум: разные аналитики ставят разную метку одному объекту.
- Задержка: атака помечается только после её разбора – иногда через дни или недели.
- Неполнота: помечена только малая часть положительных примеров, остальные – «неизвестно».
- Смещение: метка отражает то, что мы умеем ловить, а не всё, что есть.

Все четыре проблемы – это часть постановки задачи. Их игнорирование приводит к моделям, которые «работают на тесте», но не работают в эксплуатации.



Частая ошибка: «есть размеченный датасет – постановка готова»

Самое опасное недопонимание у тех, кто берёт публичные ИБ-датасеты

ЧАСТАЯ ОШИБКА

«Скачал NSL-KDD / CIC-IDS-2018 / EMBER, там есть метки атак – значит, задача поставлена. Осталось обучить модель». Так начинают почти все курсовые работы и значительная часть pet-проектов.

ПОЧЕМУ ЭТО НЕВЕРНО

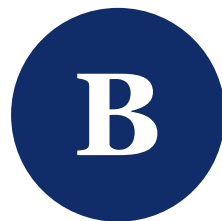
Чужая разметка собиралась под чужой сценарий. В CIC-IDS-2018 метки расставлены по правилам авторов – конкретные атаки, конкретное окно времени, конкретный лаб-стенд. Ваш SOC ловит другое.

Объект анализа в датасете может не совпадать с вашим. В NSL-KDD объект – отдельная сессия, а вам, возможно, нужен пользователь за день. Та же разметка, перенесённая на другой объект, перестаёт быть корректной.

Распределение положительного класса искусственное. В публичных датасетах доля атак часто 5-50%, в реальном трафике – доли процента. Модель, обученная на CIC-IDS-2018 с её балансом классов, в проде ведёт себя иначе.



Б Л О К В



Типология ML-постановок в ИБ

Пять базовых типов ML-задач, три режима разметки и четыре прикладных постановки в задачах информационной безопасности. Какая постановка уместна в каком сценарии.

слайды 23 - 31 · 9 слайдов



Пять базовых типов ML-задач

24 / 47

Часть 3 · Блок В

Каждый тип – отдельный способ ответить на вопрос «что делать с объектом»

Любая ML-задача в ИБ сводится к одному из пяти базовых типов. Выбор типа – это часть постановки. Каждый тип имеет свою метрику, свой способ обучения и свой режим использования результата.

ТИП ЗАДАЧИ	ЧТО МОДЕЛЬ ДЕЛАЕТ	ПРИМЕР В ИБ
Классификация	Относит объект к одному из K классов.	Файл – <i>malware / benign</i> ; запрос – <i>SQLi / нет</i> .
Регрессия	Предсказывает числовое значение.	Ожидаемое число попыток входа за следующий час.
Ранжирование	Расставляет объекты в порядке приоритета.	Сортировка алертов SOC по риску для триажа.
Кластеризация	Группирует похожие объекты без меток.	Объединение похожих образцов <i>malware</i> в семейства.
Аномалии	Помечает объекты, не похожие на «норму».	Отклонения в поведении пользователя или хоста.

Дальше в этом блоке разберём прикладные постановки в ИБ – детектирование, классификация, *triage*, ранжирование, *anomaly detection* и группировка событий – и покажем, чем они отличаются по смыслу, а не только по названию.



Что у нас есть из разметки – определяет, как мы вообще обучаем модель

Параллельно типу задачи существует другое деление: что у нас есть из меток. От этого зависит, какие методы доступны и какие гарантии можно получить. В ИБ это деление особенно важно – полная разметка встречается редко.

SUPERVISED

Обучение с учителем

Для каждого объекта известна метка y .
Модель учится отображать $x \rightarrow y$.

Пример. CIC-IDS-2018: каждому flow известна метка Benign или тип атаки.

UNSUPERVISED

Обучение без учителя

Меток нет. Модель работает только со структурой признаков.

Пример. Группировка похожих malware-сэмплов без знания их семейств.

SEMI-SUPERVISED

Полуразметка

Помечена малая часть данных.
Остальное – без меток.

Пример. 100 подтверждённых фишинговых писем + миллионы непомеченных.

В ИБ полностью supervised-постановка – редкость. Чаще встречается semi-supervised или unsupervised. Это влияет на выбор метода – но не отменяет необходимость явно сформулировать задачу.



Детектирование vs классификация

26 / 47

Часть 3 · Блок В

Внешне похожие задачи с разной постановкой и разной метрикой

В русскоязычной литературе по ИБ слова «детектирование» и «классификация» часто употребляют как синонимы. В контексте ML это разные задачи: у них разные цели, разная метрика и часто разная разметка.

ДЕТЕКТИРОВАНИЕ

Есть или нет?

Вопрос: является ли объект подозрительным?

Выход: бинарная метка или скор риска.

Метрика: precision, recall, ROC-AUC.

Пример: детектор фишинговых писем.

КЛАССИФИКАЦИЯ (МНОГОКЛАССОВАЯ)

Какого из K типов?

Вопрос: к какому из K типов относится объект?

Выход: класс из заранее заданного словаря.

Метрика: macro-F1, confusion matrix, per-class recall.

Пример: классификатор семейства malware.

Путать эти задачи опасно: если SOC нужен «детектор» (бинарный сигнал), а вы строите многоклассовый классификатор — у вас другая разметка, другая метрика и другой алгоритм. И наоборот.



Triage и приоритизация алертов

27 / 47

Часть 3 · Блок В

Случай, когда правильная постановка – это ранжирование, а не классификация

ИБ-КЕЙС · TRIAGE АЛЕРТОВ SOC

В SOC ежедневно приходит 10 000 алертов от разных источников: IDS, EDR, SIEM-правил. Аналитики физически могут разобрать ~500 в день. Вопрос: какие именно 500 разбирать?

Это НЕ задача классификации

Бинарный классификатор ответит «есть атака / нет атаки» с какой-то метрикой. Но даже при precision = 0.9 на 10 000 алертах мы получим ~1000 положительных предсказаний – больше, чем может разобрать команда. Решение «классифицируй и покажи всё с меткой attack» не работает.

Это задача ранжирования

Правильная постановка: отсортировать алерты по риску так, чтобы в первых 500 концентрировалось максимум реальных инцидентов. Метрика – **recall@500** или **NDCG@500**. Целевая переменная – порядок, а не метка.



Когда разметки атак нет или её мало – другая постановка задачи

Классификация атак требует разметки: для каждого исторического объекта известно, был ли это инцидент. Когда такой разметки нет (или есть лишь для малой части), задачу формулируют иначе – как поиск аномалий: учим модель различать «обычное» поведение и помечаем отклонения для разбора аналитиком.

КЛАССИФИКАЦИЯ АТАК · SUPERVISED

Нужно: размеченные положительные примеры известных атак.

Сильная сторона: ловит то, на чём училась, с предсказуемой точностью.

Слабая сторона: не видит атак, не похожих на исторические; нужен живой процесс пополнения разметки.

ПОИСК АНОМАЛИЙ · UNSUPERVISED

Нужно: только «нормальные» данные, можно вообще без меток атак.

Сильная сторона: может заметить ранее не виданное отклонение.

Слабая сторона: много false positives – «не похожее на норму» ≠ «атака». Нужен человек в петле.

Выбор между этими постановками – это решение о том, есть ли у вас живая разметка и устраивает ли вас её полнота. Подробно – в L11 «Обучение без учителя и поиск аномалий».



Группировка событий: когда полезна кластеризация

Не «классифицировать», а «объединять похожее» – отдельный класс задач

Кластеризация – задача без меток: мы не предсказываем класс, а строим группы похожих объектов. В ИБ это полезно тогда, когда задача – не «поставить метку», а «уменьшить количество разборов» или «увидеть структуру в массе событий».

Типовые применения в ИБ

Объединение алертов

В SOC за час пришло 800 однотипных алертов. Кластеризация сводит их в 20 групп – аналитик разбирает 20, а не 800.

K-means / DBSCAN по признакам алертов.

Семьи malware

Тысячи новых сэмплов в день. Кластеризация помогает увидеть, что 90% – это варианты 30 известных семейств.

Кластеризация по признакам файлов или поведения.

Профили пользователей

Кластеризация поведения пользователей выделяет типы (админ, разработчик, бухгалтер). Аномалия = не похож ни на один тип.

Кластеризация на поведенческих признаках.



Частая ошибка: «возьмём классификацию» по умолчанию

Самая частая ошибка выбора типа задачи в курсовых и pet-проектах

ЧАСТАЯ ОШИБКА

«Это задача классификации» – звучит по умолчанию, как только в данных появилась метка у. Студенты и инженеры выбирают классификацию по инерции, даже когда сценарий требует ранжирования, кластеризации или anomaly detection.

ПОЧЕМУ ЭТО ВЕДЁТ В ТУПИК

Когда пользователю важен порядок – классификация даёт «свалку». SOC с потоком 10 000 алертов в день получит 1500 положительных предсказаний без приоритета. Это хуже, чем правильное ранжирование топ-500.

Когда положительный класс редкий и плохо размечен – классификация не учится. Если на 1 000 000 событий 50 положительных и 100 неточно помеченных, supervised-классификатор переобучается под шум. Anomaly detection ставит задачу иначе.

Когда классов слишком много или они меняются – классификация хрупкая. Семейств malware десятки тысяч, новые появляются ежедневно. Жёсткий K-классовый классификатор устаревает за недели. Кластеризация переживает это лучше.



Мини-резюме блоков Б и В

31 / 47

Часть 3 · Блок В

Пять понятий, которые превращают «обучить модель» в инженерную постановку задачи

Прошли два самых длинных блока: объект анализа и целевая переменная (Блок Б), типология ML-постановок (Блок В). Если соединить их вместе – получается чек-лист из пяти вопросов, на которые нужно ответить до того, как начинать обучать модель.

1 Какой у вас объект анализа?

Не «откуда данные», а «что именно классифицируем».

2 Какая у объекта целевая переменная?

Бинарная, многоклассовая, числовая или порядок.

3 Что у вас есть из разметки?

Supervised, semi-supervised или unsupervised.

4 Какой тип задачи уместен?

Классификация, регрессия, ранжирование, кластеризация или anomaly detection.

5 Какая прикладная постановка?

Детектирование, классификация атак, triage, поиск аномалий или группировка.



Б Л О К Г



Данные, цена ошибок и baseline

Что в ИБ-данных мешает сразу обучать модель, почему цена ошибок – часть постановки, а не часть метрики, и зачем нужен baseline до выбора сложной модели.

слайды 32 - 37 · 6 слайдов



Что отличает ИБ-данные от учебных датасетов

ИБ-данные имеют четыре характерных свойства, которые ломают наивный подход «возьмём датасет – обучим модель». Эти свойства – часть постановки задачи, а не «помехи, которые потом обрабатываем».

1 Дисбаланс классов

Атаки – редкие события. Положительный класс часто 0.01-1% выборки. Ассигнатура теряет смысл, обычные метрики тоже искажаются.

разворачиваем на следующем слайде; метрики под дисбаланс – в L04

2 Шум и задержка разметки

Разметка приходит с опозданием (после разбора инцидента), с шумом (разные аналитики ставят разные метки), неполнотой (помечена малая часть).

подробно – в Блоке Б, слайд 21; влияние на валидацию – в L05

3 Зависимость наблюдений

Flow-записи одной сессии, события одного хоста, письма от одного отправителя – не независимы. Случайный train/test split даёт оптимистичную метрику.

детально – в L05; временная специфика – в L12

4 Сдвиг распределений

Атакующий меняет тактику, инфраструктура обновляется, поведение пользователей дрейфует. Модель, обученная на прошлом квартале, может не работать в следующем.

concept drift и robustness – в L17 и L18



Почему привычные метрики перестают работать, когда положительный класс редкий

В типичном корпоративном трафике атаки – это доли процента. Это меняет почти всё: какой baseline разумен, какая метрика осмысленна, как готовить выборку. В этом слайде показываем эффект на простом примере.

ПРИМЕР · 1 000 000 СЕТЕВЫХ FLOW В СУТКИ

0.1 %

доля атак в сутки
(~1 000 из 1 000 000)

99.9 %

точность baseline
«всегда отвечай Benign»

0 %

recall этого baseline:
ни одной атаки не поймано

Модель, которая просто всегда отвечает «Benign», даёт ассурасу 99.9% – и ловит ноль атак. Поэтому ассурасу на дисбалансных задачах ИБ – нерабочая метрика. Нужны метрики, которые штрафуют за пропуск редкого класса.

Метрики под дисбаланс – precision, recall, F1, PR-AUC, recall@k – подробно разберём в L04 «Метрики качества и цена ошибок».



Не часть оценки модели потом, а часть формулировки задачи сейчас

ОПРЕДЕЛЕНИЕ

Цена ошибок – это эксплуатационные последствия двух типов ошибок модели: **false positive** (ложно поднятый алерт) и **false negative** (пропущенный инцидент). В ИБ эти цены почти всегда асимметричны и зависят от сценария применения системы, а не от модели.

ИБ-КЕЙС · ВЫСОКАЯ ЦЕНА FP

Автоматический антифрод

Транзакции блокируются автоматически. FP = заблокирован честный клиент → жалоба, отток, репутация. FN = пропущенное мошенничество → возврат денег банком. Часто 1 пропуск ≈ десяткам ложных блокировок по совокупной цене.

ИБ-КЕЙС · ВЫСОКАЯ ЦЕНА FN

Детектор APT в SOC

Модель ищет следы целенаправленной атаки. FP = алерт аналитику → 15 минут разбора. FN = пропущенный взлом → недели присутствия атакующего, утечка данных, миллионы убытков. Здесь 1 FN дороже сотен FP – порог сдвигают в сторону низкого FN.



Baseline: минимально разумная точка сравнения

Первое появление термина в курсе. Дальше используем без переопределения

ОПРЕДЕЛЕНИЕ

Baseline – это простейшая модель или правило, которое решает задачу без машинного обучения или с минимально возможным ML. Качество вашей модели имеет смысл только относительно baseline.

Что обычно берут как baseline

Тривиальный

Самый частый класс / постоянное значение / случайный ответ.

Пример. «Всегда Benign» – даёт верхнюю границу ассигасу при дисбалансе.

Правило-эвристика

Простое правило из практики ИБ или регулярное выражение.

Пример. «Алерт, если число попыток входа > 10 за минуту».

Простая модель

Логрегрессия на нескольких признаках или дерево глубины 3.

Пример. Линейная модель из L06 как baseline для бустинга из L08.

Baseline-дисциплина – сквозная линия курса. Конкретные baseline для каждого семейства моделей: линейная модель в L06, простое дерево в L08, MLP в L13, TF-IDF + линейная модель в L15.



Частая ошибка: сравнение моделей без baseline

37 / 47

Часть 3 · Блок Г

Почему отчёт «наша модель даёт 0.95» без baseline ничего не значит

ЧАСТАЯ ОШИБКА

В курсовом отчёте: «Мы обучили градиентный бустинг, accuracy на тесте 0.95, precision 0.93, recall 0.91». Без baseline это число – не результат. Это число.

ПОЧЕМУ ЭТО НЕВЕРНО

Без baseline нельзя понять, что вы вообще улучшили. Может, тривиальный «всегда Benign» даёт accuracy 0.999 – тогда 0.95 это деградация. Может, простое правило по числу попыток входа даёт 0.97 – тогда сложная модель не нужна. Без точки сравнения число «0.95» бессмысленно.

Без baseline нельзя обосновать сложность модели. Бустинг сложнее линейной модели в эксплуатации: больше параметров, тяжелее интерпретировать, дольше учится. Если линейная даёт почти то же качество – выбор бустинга нужно обосновать дельтой метрики против него, а не абсолютным числом.

Без baseline невозможно говорить о практической пользе. В SOC «модель ловит 0.91 атак» бессмысленно, если правило «10 попыток входа за минуту» ловит 0.88 без ML вообще. Baseline отвечает на вопрос, ради чего вы вообще делали ML-проект.



Применяем чек-лист постановки задачи на конкретном сценарии

ИБ-КЕЙС · ПОЧТОВЫЙ ШЛЮЗ КРУПНОЙ КОМПАНИИ

100 000 сотрудников, ~5 млн писем в сутки. Цель – снизить успешные фишинговые атаки. Применим чек-лист из 5 вопросов от слайда 31.

№	ВОПРОС	ОТВЕТ ДЛЯ ЭТОГО КЕЙСА
1	Объект анализа	Отдельное письмо (не пользователь, не домен, не поток).
2	Целевая переменная	Бинарная: фишинг / легитимное ($y \in \{0, 1\}$).
3	Разметка	Жалобы пользователей + sandbox-анализ ссылок + ручной разбор. Шумная, с задержкой.
4	Тип задачи	Детектирование (бинарное), скор риска.
5	Режим использования	Автомат: фишинг → карантин, не в инбокс. FP высокая, FN недопустим.

Baseline. Правило «блокировать любое письмо с внешним отправителем» даёт $recall \approx 1.0$, но $precision \approx 0.01$. Никуда не годится – но это точка отсчёта.



Тот же чек-лист на сквозном датасете CIC-IDS-2018

ИБ-КЕЙС · АНАЛИЗ СЕТЕВОГО ТРАФИКА НА CIC-IDS-2018

Те же 5 вопросов – но контекст другой: сетевой трафик, SOC, аналитики, ловушки с временной зависимостью наблюдений.

№	ВОПРОС	ОТВЕТ ДЛЯ ЭТОГО КЕЙСА
1	Объект анализа	Отдельный flow (запись NetFlow). Не пакет, не сессия – flow.
2	Целевая переменная	Многоклассовая: Benign + 14 типов атак. Или бинарная для триажа.
3	Разметка	Дана авторами CIC: имитация атак в лабораторной среде. Не «дикая».
4	Тип задачи	Ранжирование под триаж SOC. Метрика – recall@k на потоке flow.
5	Режим использования	Триаж: модель сортирует, аналитик разбирает топ. Не автоблокировка.

Ловушка. Flow одной сессии или одной атакующей машины не независимы. Случайный train/test split даст оптимистичный recall. Корректно – time-based split (детально в L05).



Сводный портрет ИБ-задач, который отличает их от учебных постановок ML

Два разобранных кейса разные – но в них есть общие черты, специфичные именно для ИБ. Их нужно держать в голове при постановке любой ИБ-задачи. Это не «помехи», а свойства области, к которым приходится адаптировать и постановку, и модели, и метрики.

1 Редкий положительный класс

Атаки – это доли процента (а не 50/50, как в учебном датасете). Это влияет на метрику, на разметку, на дизайн обучающей выборки.

2 Активный противник

Атакующий целенаправленно меняет тактику, чтобы обойти модель. В ИБ это отдельная угроза, которой нет в учебном ML – её разворачиваем в L17-L19.

3 Асимметричная цена ошибок

FP и FN почти никогда не стоят одинаково. Какая ошибка дороже – зависит от сценария: автомат, триаж или помощник.

4 Человек в петле

Результат модели обычно не действие, а информация для аналитика. Это поднимает значение интерпретируемости и удобства интерфейса.



Что мы сделали в L03 и что появится в L04, L05 и в L06-L09

Корректная постановка задачи – необходимое условие. Но не достаточное. Дальше нужны метрики (как оценивать качество под выбранную постановку) и валидация (как мерить честно). Покажем, куда переходит каждая из главных нитей этой лекции.

СЛЕДУЮЩАЯ ЛЕКЦИЯ

L04

Метрики и цена ошибок

- precision, recall, F1, ROC-AUC
- PR-AUC и recall@k для дисбаланса
- стоимостная матрица ошибок
- разбор на CIC-IDS-2018

превращает «цену ошибок» из L03 в метрику.

ЧЕРЕЗ ЛЕКЦИЮ

L05

Валидация и leakage

- holdout, k-fold, time-based, group split
- утечки данных и как их искать
- воспроизводимость эксперимента
- журнал экспериментов

забирает «зависимость наблюдений» из L03 и превращает в схему валидации.

ДАЛЬШЕ В БЛОКЕ 1

L06 - L09

Семейства моделей

- L06: линейные модели + log-loss
- L07: регуляризация и порог
- L08: деревья и бустинг
- L09: интерпретация и анализ ошибок

конкретные baseline-модели для каждого семейства.



Шесть утверждений, которые мы понесём дальше в курс

Если из всей лекции забудется всё, кроме шести строк ниже – лекция выполнила свою задачу. Эти утверждения становятся опорой для следующих лекций блока 1, а потом возвращаются в L16, L18, L20.



Модель ≠ система

ML-компонент – один шаг из пяти: данные, подготовка, модель, постобработка, решение. Качество системы – произведение качества всех пяти.



Объект анализа фиксируется явно

Не «откуда данные», а «что именно классифицируем». Из одного источника можно построить несколько разных ML-задач.



Цена ошибок – часть постановки

FP и FN почти всегда асимметричны. Стоимость определяется сценарием применения, а не моделью. В L04 – превращается в метрику.



Постановка предшествует выбору алгоритма

До того как сравнивать модели, нужно ответить на пять вопросов: объект, целевая переменная, разметка, тип задачи, режим использования.



Тип задачи выбирается под сценарий

Классификация по инерции – частая ошибка. SOC с потоком алертов – это ранжирование. Нет разметки – anomaly detection.



Baseline обязателен

Качество модели имеет смысл только относительно простой точки сравнения. 0.95 без baseline – не результат, а число.



Когда чек-лист постановки задачи нужен – и когда он избыточен

Рамка «модель как компонент системы» + чек-лист из 5 вопросов – это инженерный инструмент. Он разработан под конкретный тип работы. В других задачах он либо не нужен, либо может мешать.

ПРИМЕНЯТЬ

Когда вы строите ML-компонент

- Задача от заказчика SOC, антифрод, EDR.
- Курсовой или дипломный проект по ML в ИБ.
- Pet-проект для портфолио на реальных данных.
- Pilot для оценки целесообразности ML.
- Любой случай, где результат модели будет использован человеком или системой.

МОЖНО НЕ ПРИМЕНЯТЬ

Чисто исследовательские задачи

- Сравнение алгоритмов на бенчмарке для статьи.
- Учебное упражнение «обучи модель на iris».
- Воспроизведение чужого результата как есть.
- Соревнование Kaggle с фиксированной метрикой.
- Любой случай, где никто не будет использовать модель за пределами вашего ноутбука.



Связь с другими лекциями курса

44 / 47

Часть 5 · Итоги

Карта того, куда из L03 уходят сквозные линии

L03 не существует отдельно – она запускает две сквозные линии курса и подбрасывает термины, которые подхватываются в восьми последующих лекциях. Эта карта поможет вам ориентироваться при возвращении к материалу.

ЛЕКЦИЯ	ТЕМА	ЧТО ЗАБИРАЕТ ИЗ L03
L04	Метрики и цена ошибок	цена FP / FN, асимметрия, метрики под дисбаланс
L05	Валидация и leakage	зависимость наблюдений, шум разметки
L06	Линейные модели	baseline-дисциплина (первая модель = baseline)
L07	Калибровка и выбор порога	режимы автомат / триаж / помощник
L08	Деревья и бустинг	baseline-дисциплина (простое дерево как baseline)
L11	Кластеризация и аномалии	anomaly detection как отдельная постановка
L16	LLM в задачах ИБ	модель как компонент системы (через human-in-the-loop)
L20	Reliability note	вся рамка возвращается в итоговую оценку надёжности



3 источника, которые расширят понимание материала этой лекции

Эта лекция концептуальная, и материал в её точности нельзя «найти в учебнике» – он собран из инженерной практики ML в ИБ. Источники ниже дают академическую и индустриальную опору для разобранных идей.

1

Bishop C. M. – Pattern Recognition and Machine Learning

Springer, 2006 · глава 1 «Introduction», стр. 1-32

Концептуальная рамка ML: объект, признак, целевая переменная, типы задач (классификация, регрессия). Базовый словарь, на который опирается вся лекция.

2

Hastie T., Tibshirani R., Friedman J. – The Elements of Statistical Learning

Springer, 2nd ed., 2009 · глава 2 «Overview of Supervised Learning», стр. 9-41

Обзор supervised-постановок, цена ошибок (loss functions) на разных задачах, концепция baseline и сравнения моделей. Покрывает большую часть терминов из блоков А и Г.

3

Sommer R., Paxson V. – Outside the Closed World

IEEE Symposium on Security & Privacy, 2010 · стр. 305-316

Классическая статья о специфике ML в ИБ: редкий положительный класс, активный противник, асимметричная цена ошибок, проблемы публичных датасетов. Прямой источник идей блока Г и Части 4.



Для тех, кто хочет глубже – или подготовить пилотный проект

ДОПОЛНИТЕЛЬНОЕ ЧТЕНИЕ

Apruzzese G. et al. – ML in Cybersecurity

ACM DTRAP, 2023

Arp D. et al. – Dos and Don'ts of ML in Security

USENIX Security, 2022

Pendlebury F. et al. – TESSERACT

USENIX Security, 2019

Joseph A. D. et al. – Adversarial Machine Learning

Cambridge UP, 2018 · гл. 1-2

ДАТАСЕТЫ И ТУТОРИАЛЫ

CIC-IDS-2018 – официальная страница датасета

unb.ca/cic/datasets/ids-2018.html

NSL-KDD – для сравнения с CIC-IDS

unb.ca/cic/datasets/nsl.html

EMBER – датасет для классификации PE-файлов

Endgame, 2018 · github.com/elastic/ember

scikit-learn: «An introduction to machine learning»

scikit-learn.org/stable/tutorial



Двенадцать ключевых терминов, которыми мы будем пользоваться весь курс

Объект анализа

Единица данных, относительно которой модель делает одно предсказание.

Целевая переменная

Что модель должна предсказывать по объекту: метка, класс, число, порядок.

Сценарий применения

Конкретная задача, ради которой система используется; кто принимает решение.

Режим использования

Автомат / триаж / помощник – три способа использовать выход модели.

Supervised

Обучение с учителем: для каждого объекта известна метка y .

Unsupervised

Обучение без учителя: меток нет, есть только структура признаков.

Semi-supervised

Помечена малая часть данных, остальное – без меток.

Детектирование

Задача «есть или нет»: бинарный сигнал риска по объекту.

Ранжирование

Расстановка объектов в порядке приоритета. Метрика – $\text{recall}@k$ или $\text{NDCG}@k$.

Anomaly detection

Поиск отклонений от «нормы» без явной разметки атак.

Цена ошибок

Эксплуатационные последствия FP (ложный алерт) и FN (пропуск).

Baseline

Простейшая модель или правило, относительно которого имеет смысл качество модели.